

Universidade do Vale do Rio dos Sinos

Fundamentos de Criptografia

Criptografia Aplicada

Prof. Luciano Ignaczak (lignaczak@unisin.br)

Pedro Boeira Webber

Atividade Prática –Criptografia como Controle de Segurança Corporativo

Introdução

A Security X é uma empresa com mais de 35 anos de experiência na área da tecnologia da informação. Hoje a Security X oferece serviços de segurança da informação, contando com monitoramento, resposta a incidente, gestão de identidade e acesso, proteção de e-mail, entre outros. Um dos produtos oferecidos por ela é o Super Defense Center (SDC), uma equipe especializada que atua com monitoramento 24/7 e conta com 15 analistas.

Comunicação via e-mail

A gestão e resposta a incidente é um importante serviço oferecido pela Security X e para isso é necessária uma comunicação constante entre os analistas do SDC e os clientes. Toda a comunicação do SDC com o cliente é feita através de e-mail utilizando o Service Now que atua como gerenciador de chamados.

Durante a triagem de incidentes é necessário o envio de alertas para o cliente, contendo informações do evento e evidências pertinentes. As informações enviadas nesses alertas contêm dados sensíveis e que, se expostos, gerariam grandes danos ao cliente, e consequentemente a Security X. A utilização de um protocolo criptográfico poderia melhorar a segurança e privacidade das mensagens trocadas entre clientes e analistas. Uma camada a mais de criptografia em cima do conteúdo do e-mail faria com que, caso a mensagem fosse interceptada, ela não teria como ser lida, assim apenas o cliente poderia ter acesso às informações dela.

Uma das maneiras de fazer essa implementação de criptografia seria a utilização de criptografia assimétrica juntamente com criptografia simétrica. Utilizando o protocolo AES e o protocolo RSA. Cada cliente teria um par de chave RSA (uma chave pública que é transmitida para os analistas, e uma chave privada que apenas o cliente possui) e assim a troca poderia ser feita da seguinte maneira:

- O analista faz a triagem do evento e criptografa usando o AES com uma chave simétrica k o conteúdo da mensagem que será enviada ao cliente;
- Em seguida utilizado o protocolo RSA e a chave pública P_u do cliente desejado, criptografa a chave k ;
- O analista envia os a mensagem criptografada e a chave k criptografada para o cliente. A chave k criptografada pode ser enviada através de um canal seguro;
- O cliente ao receber a mensagem, utiliza a sua chave privada P_r com o protocolo RSA para descriptografar a chave k ;
- Em seguida utiliza a chave k com o protocolo AES para descriptografar e ler a mensagem;

Esse protocolo garante a confidencialidade na troca de mensagens entre analista e cliente, esse processo também garante que apenas o cliente determinado poderá ler a mensagem, assim evitando vazamento de informações (também protege caso o analista enviar a mensagem para o cliente errado).

Criptografia de arquivos

Outro processo importante no funcionamento da empresa é o armazenamento de arquivos. Atualmente os arquivos do SDC contendo manuais, informações sobre a infraestrutura do cliente e relatórios de desempenho são salvos no Sharepoint e organizados em pastas separadas.

A criptografia poderia garantir a confidencialidade dos documentos, assim apenas as pessoas de certo cargo poderiam acessá-los. Os analistas da Security X são divididos em 3 cargos: Analista de Segurança da Informação L1, Analista de Segurança da Informação L2 e Analista de Segurança da Informação L3.

Para fazer a implementação, seriam criados 3 pares de chave RSA. Todos os analistas terão as chaves públicas dos 3 níveis e terão as chaves privadas do seu nível e dos níveis abaixo.

- L3 terão as 3 chaves privadas
- L2 terão a sua chave privada e a chave privada dos L1
- L1 terão apenas a sua chave privadas
- Todos terão as 3 chaves públicas

O protocolo criptográfico usaria o protocolo AES com criptografia simétrica, juntamente com o RSA, utilizando criptografia assimétrica. O arquivamento de arquivos poderá ser feito da seguinte maneira.

- O analista decide qual o nível necessário para determinado documento;
- Em seguida gera uma chave simétrica k e utiliza o protocolo AES para criptografar o documento;
- Depois utiliza a chave privada P_r do nível condizente para criptografar a chave simétrica k ;
- O arquivo é salvo na sua pasta junto com a chave k criptografada;

- Para ler o arquivo, o analista deve descriptografar o k com a chave P_r do nível adequado;
- Em seguida deve utilizar a chave k para descriptografar o arquivo;

Esse protocolo garantirá a confidencialidade dos arquivos salvos e fará com que apenas os analistas com o cargo pertinente possam acessar seus arquivos. Assim, os L3 poderão acessar todos os arquivos; Os L2 poderão acessar os seus arquivos e os arquivos dos L1; Os L1 poderão acessar somente os seus arquivos.